FIVUCSAS

Face and Identity Verification Using Cloud-based SaaS

Multi-tenant biometric authentication with active-liveness anti-spoofing

Ahmet Abdullah Gültekin · Ayşe Gülsüm Eren · Ayşenur Arıcı

Advisor: Assoc. Prof. Dr. Mustafa Ağaoğlu · CSE4197 / CSE4198 · Spring 2025–2026

Marmara University · Faculty of Engineering · Department of Computer Engineering

0%
Replay-attack false-accept
n=120 recorded-video attempts

< 1s
End-to-end verification
P95 = 950 ms, CPU only

10
Composable auth factors
face + voice + NFC + WebAuthn + ...

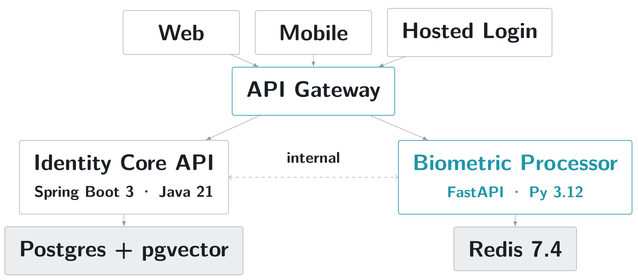
01 Problem

Online authentication is fragmented. Passwords leak, SMS OTPs are SIM-swappable, hardware keys exclude phone-only users, and most biometric services trust a single passive signal — a still selfie or a recorded clip — that a prepared attacker can replay.

GDPR and KVKK demand verifiable consent, right to erasure, and data portability; consumer auth stacks treat these as an afterthought.

Goal. A tenant-configurable, multi-modal identity platform where any subset of ten authentication factors composes into MFA flows — and where every biometric factor is protected by an *active*, randomised liveness challenge a recorded video cannot replay.

02 Architecture



Biometric service has no public route — Docker network only, API-key gated.

03 Passive vs. active liveness

Passive only

Single frame → texture / colour cues.

- ✗ Photo of phone screen — *often passes*
- ✗ Recorded clip — *passes*
- ✗ Deepfake injection — *often passes*

Active challenge

Randomised n-step facial-action sequence + landmarks + passive layer.

- ✓ Photo — *fails*
- ✓ Recorded clip — *fails (sequence mismatch)*
- ✓ Deepfake — *must hit cues live*

04 Contributions

C1. Tenant-configurable composition of 10 authentication factors into MFA flows declared at the admin layer.

C2. Active randomised liveness — n-step facial-action sequence bound to a per-attempt nonce, verified server-side against landmark thresholds and temporal consistency.

C3. Pipeline decomposition along the OIDC-contract / ML-iteration boundary into two horizontally-scalable services on a private Docker network.

C4. Embedding-at-rest encryption — Facenet512 embeddings wrapped in Fernet (AES-128-CBC + HMAC-SHA-256) prior to write into pgvector.

C5. Regulator-aware data lifecycle — tenant-scoped soft-delete, scheduled purge, audit-logging satisfying GDPR Art. 15 / 17 and KVKK.

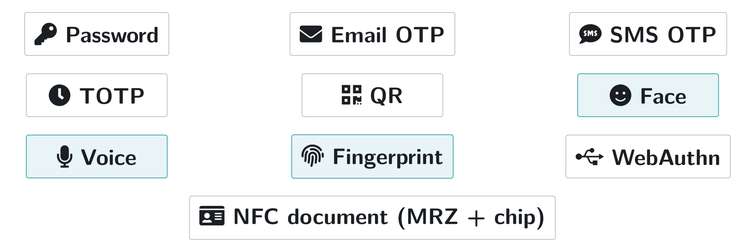
05 Methods

Per verification attempt:

1. Server issues a randomised action sequence (n=3–5) + nonce.
2. Client streams 60-frame landmark vectors (MediaPipe FaceLandmarker, 468 points).
3. Server checks each action against EAR / MAR / yaw thresholds + temporal consistency.
4. UniFace MiniFASNet runs a passive spoof check in parallel.
5. Embedding (Facenet512) encrypted with Fernet (AES-128-CBC + HMAC-SHA-256) and matched against the user vector in pgvector (HNSW).

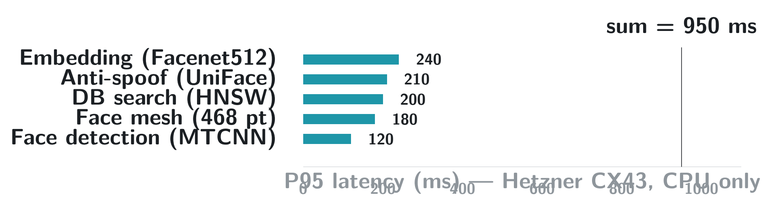
60 Flyway migrations · 5 submodules · self-hosted GitHub runner on Hetzner CX43 · 1 820+ tests · 8 ADRs.

06 10 composable factors



Teal tiles = wrapped in active-liveness; any subset composes into a tenant MFA flow.

07 Experiments & results



Quality metric	Target	Observed
Replay-attack FAR (n=120)	< 1%	0.0%
Passive-spoof AUC (internal)	> 0.95	0.97
Backend tests	green	633 / 633
Web Vitest + Playwright	green	619 + 27
Mobile (KMP) units	green	425 / 425

08 Conclusion

Production-grade, GDPR-compliant biometric authentication *is* achievable on commodity hardware when the system is decomposed along its right axis — a frozen OIDC contract on one side, an iterating ML pipeline on the other — and when liveness is treated as an active, challenge-driven property rather than a passive signal alone. Measured 0 / 120 replay-attack false-accepts and a 0.97 passive-spoof AUC are both within practical deployment limits on a single CPU server.

09 Future work

— BYOD tenant DB. Enterprise tenants host biometric data in their own database, schema